SANA'A UNIVERSITY

Yemen

Dynamic k-Zero Day Safety Metric for Software-Defined Networks (SDN): Real-Time Risk Assessment and Mitigation

Master's Research Proposal

Cyber Security

Prepared by

Sam Measar Nasser Measar

Master's Degree in Cyber Security

Sana'a University, Yemen

Abstract

Software-Defined Networking (SDN) offers centralized visibility and programmable forwarding, but frequent topology changes, flow-rule modifications, and controller decisions can invalidate network-risk estimates derived from static configurations. The classical *k-zero day safety* metric estimates a target's resistance to unknown-vulnerability attack chains by counting the minimum number of distinct zero-day vulnerabilities required along a feasible attack path. Its interpretation is attractive for unknown-threat risk reasoning; however, operationalizing the metric under rapidly changing SDN state raises unresolved questions concerning attack-graph maintenance, measurement freshness, uncertainty, and response overhead. This research proposes to design and experimentally assess a *dynamic, SDN-aware* k-zero day safety framework combining controller events and OpenFlow telemetry, incremental attack-graph maintenance, flow-based anomaly evidence, and policy-controlled mitigation. The study will formally specify network-state transitions and a composite risk score, implement a prototype in a Mininet-based laboratory, and compare event-driven incremental assessment against static and full-recomputation baselines. Controlled topology, forwarding-policy, traffic-anomaly, and adversarial-path scenarios will be used to evaluate risk-state consistency, update latency, detection error, operational overhead, and mitigation effectiveness. Because true unknown vulnerabilities cannot be directly enumerated or reliably labeled in a testbed, explicit surrogate assumptions and sensitivity tests will delimit what the findings can establish. The anticipated contribution is a reproducible method for connecting an established structural security metric to timely SDN decisions, together with empirical evidence about its benefits, costs, and limitations. *No implementation or empirical results are claimed in this proposal.*

Keywords: software-defined networking; k-zero day safety; attack graph; zero-day vulnerability; OpenFlow; anomaly detection; dynamic risk assessment; incremental computation; mitigation; Mininet.

Contents

1 Introduction and Research Background **1**

2 Problem Statement **2**

3 Research Gap **2**

4 Research Aim and Objectives **3**

5 Research Questions and Hypotheses **3**

6 Significance of the Research **4**

7 Literature Review and Related Work **4**

7.1 Classical k-Zero Day Safety and Network Diversity 4

7.2 Attack Graphs and Lateral Movement 4

7.3 SDN Security and Flow-Based Detection 5

7.4 Dynamic Risk Measurement and the Remaining Opportunity 5

8 Proposed Research Methodology **5**

8.1 Research Design and Phases 6

8.2 Experimental Architecture 6

8.3 Monitoring and Feature Engineering 7

8.4 Anomaly Detection and Calibration 7

8.5 Dynamic Attack-Graph Representation 8

8.6 Incremental Update Strategy 8

8.7 Risk Estimation and Decision Policy 8

9 Proposed Mathematical Model **9**

9.1 Network State and Attack Paths 9

9.2 Exposure, Anomaly Severity, Criticality, and Exploitability 10

9.3 Original Conceptual Composite Score 10

9.4 Proposed Bounded Refinement and Uncertainty Handling 10

9.5 Path Computation and Computational Tradeoffs 11

10 Proposed System Architecture **11**

11 Experimental Design and Evaluation Plan **12**
11.1 Testbed Configuration and Reproducibility 12
11.2 Experimental Scenarios 13
11.3 Comparison Baselines and Ablations 13
11.4 Experimental Procedure and Statistical Analysis 14
11.5 Validation of the Mathematical Assumptions 14

12 Performance Evaluation Metrics **14**
12.1 Structural and Temporal Correctness 15
12.2 Detection and Mitigation Performance 15
12.3 Operational Overhead and Scaling 15

13 Expected Results and Anticipated Contributions **15**

14 Research Limitations and Threats to Validity **16**

15 Research Ethics and Security Considerations **17**

16 Research Work Plan and Timeline **17**
16.1 Milestones and Decision Gates 17

17 Conclusion **18**

References **19**

List of Figures

1 The three SDN planes and the information/control interfaces relevant to the proposed study. . . . 1
2 Planned research phases, from formal assumptions to comparative evaluation. 6
3 Proposed SDN-aware k-zero day safety prototype and closed-loop control architecture. . . . 6
4 Proposed real-time telemetry, feature processing, risk assessment, and feedback workflow. . . . 7
5 Proposed incremental attack-graph update and consistency-check procedure. 9
6 Proposed mitigation decision, enforcement, rollback and feedback interfaces. 12

List of Tables

1 Positioning of the proposed research against relevant lines of work. . . . 5
2 Proposed telemetry inputs and their interpretation. . . . 7
3 Mathematical variables, ranges and interpretation. . . . 11
4 Planned controlled comparisons and their principal purpose. . . . 14
5 Metrics, measurements and interpretation safeguards. . . . 16
6 Proposed eight-month research schedule (• = active period). . . . 18

1 Introduction and Research Background

Modern networks are increasingly managed by software that can alter forwarding decisions and security policies with minimal operational delay. SDN separates the application, control, and data planes: applications express management intent, controllers translate policies into device operations, and programmable switches forward traffic according to installed flow rules [1, 2]. This separation offers a coherent vantage point for monitoring and enforcing network security but concentrates critical privileges in the control plane. A successful attack on a controller, a rule-management interface, or a permitted communication path can consequently affect many hosts at once.

A zero-day vulnerability is an unknown weakness whose exploitation cannot be modeled using a complete list of disclosed weaknesses. Conventional vulnerability-counting approaches therefore provide only a partial picture of exposure. Wang and colleagues introduced k-zero day safety to describe the *minimum number of distinct unknown vulnerabilities* that an attacker must exploit to compromise a designated asset [3, 4]. The metric is structural: it considers potential multi-step attack paths instead of claiming to enumerate undisclosed flaws. Subsequent work on network diversity and network attack surface underscores that deployment heterogeneity and reachability influence resistance to unknown attacks [5, 6, 7].

In an SDN deployment, forwarding-table changes, link failures, host additions, and controller policy actions may rapidly change the feasible paths between an untrusted entry point and a protected asset. A measurement computed from yesterday's topology can be exact for the old state yet wrong for the current one. Anomalous flows can also affect a response decision without changing the underlying structural k-value. This proposal therefore treats *structural safety*, *behavioral suspicion*, and *operational mitigation* as related but distinct quantities that must be updated and evaluated together.

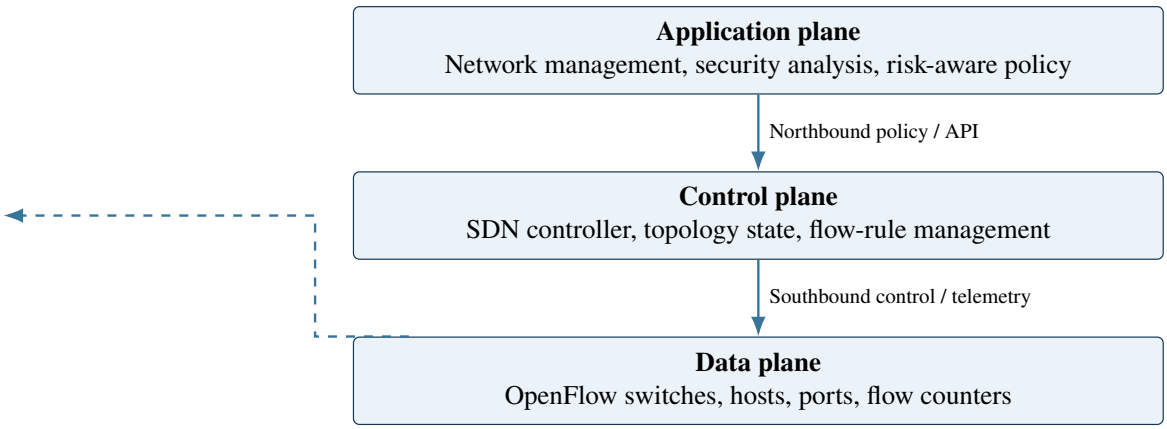


Figure 1: *The three SDN planes and the information/control interfaces relevant to the proposed study.*
Author-created conceptual schematic; informed by [1, 2].

2 Problem Statement

Classical k-zero day safety assumes that the network state represented by the attack model is sufficiently stable during the assessment. SDN violates that operational premise when flow rules and connectivity change more frequently than the risk model is refreshed. A static assessment may report that a critical target requires several independent unknown exploits while a recently installed flow rule exposes a shorter path. Conversely, a deleted rule might remove a dangerous path, but a stale assessment may continue to report excessive risk. Neither case can be resolved by improving anomaly detection alone, because *topological safety* is not equivalent to *traffic abnormality*.

A viable dynamic approach must overcome four linked technical challenges. First, it must translate controller and data-plane observations into a sufficiently accurate time-indexed attack model. Second, it must update affected paths without rebuilding the entire graph after each routine change. Third, it must combine security information without mistaking probabilistic anomaly evidence for verified exploitation of a zero-day flaw. Fourth, it must issue defensible, reversible mitigation actions while keeping controller load and unintended service disruption within acceptable bounds. The central research problem is therefore *how to maintain a timely and interpretable k-zero day safety assessment for changing SDN states, and whether using it to guide mitigation improves measured security outcomes at a tolerable operational cost.*

3 Research Gap

Classical k-zero day safety and its efficient approximations provide established structural reasoning for unknown-vulnerability exposure [3, 4, 8]. Attack-graph methods support explicit reasoning about compromise preconditions and paths, yet graph construction and updates create correctness and scalability concerns [9, 10]. Separately, SDN monitoring and detection studies demonstrate that flow counters and machine-learning techniques can support anomaly detection, but their performance depends on the selected features, data distribution, and false-positive tolerance [11, 12, 13]. Controller security work, including AVANT-GUARD, addresses switch-flow and control-plane exposure but does not by itself establish a time-indexed k-zero day safety measurement [14].

These lines of research motivate an *integration and validation gap*: there is a need to specify and evaluate a practical method that (i) maintains a target-focused k-value consistently with SDN events, (ii) separates structural attack-path evidence from anomaly-derived risk, and (iii) feeds the resulting estimate into a controlled mitigation loop with measurable delay and overhead. This is a *proposed research gap based on the supplied literature*, not a claim that no previous work has addressed related integration. A formal, up-to-date systematic novelty review will be required before any claim of first implementation or global superiority.

4 Research Aim and Objectives

Aim. To design, implement, and experimentally evaluate a dynamic k-zero day safety framework for SDN that links event-aware attack-path assessment to interpretable real-time risk scoring and operationally safe mitigation.

Specific objectives.

O1. Formalize an SDN network-state model, attacker assumptions, target selection, and path-based k-value interpretation, including missing data and mathematical edge cases.

O2. Develop a controller-integrated collection pipeline that records topology, flow-rule changes, flow counters, and timestamps with reproducible provenance.

O3. Design incremental updates to the attack graph and compare the resulting k-values with independent full-graph recomputation for correctness and update cost.

O4. Implement a distinct anomaly-severity estimator and an explicitly normalized, explainable composite risk indicator, with uncertainty and sensitivity analysis.

O5. Design a risk-driven mitigation policy with bounded actions, approval gates for disruptive changes, rollback, and feedback reassessment.

O6. Evaluate the prototype against static, full-recomputation, and detection-only baselines on controlled Mininet scenarios using paired trials and documented metrics.

5 Research Questions and Hypotheses

RQ1.
How accurately can a continuously maintained attack graph and target-specific k-value represent controller-observed SDN state transitions, compared with a full recomputation reference?

RQ2.
Under what topology sizes and flow-rule update rates does incremental maintenance reduce assessment latency and resource cost without unacceptable inconsistency?

RQ3.
Does combining structural k-safety, exposure, anomaly severity, asset criticality, and cautious exploitability estimates improve risk-based decision quality relative to structural-only or anomaly-only baselines?

RQ4.
Can policy-constrained mitigation reduce modeled target exposure and response delay without causing excessive false-positive disruption or controller overhead?

The following *testable directional hypotheses* will be evaluated, rather than presumed true:

- **H1:** Under identical update streams, incremental assessment has lower median update latency than repeated full attack-graph reconstruction while matching the reference k-values for the modeled graph.
- **H2:** On held-out controlled scenarios, risk-informed decisions offer a better detection/mitigation tradeoff than anomaly-only threshold decisions at comparable false-positive budgets.
- **H3:** Compared with no mitigation, bounded risk-driven responses reduce modeled reachability or the composite risk of the affected target without a disproportionate reduction in benign-flow service performance.

Each hypothesis specifies comparisons; the actual size, direction, and statistical certainty of effects will be determined only after experiments.

6 Significance of the Research

Scientifically, the work can clarify the interpretation of structural unknown-vulnerability metrics under continuously changing reachability and provide a reproducible evaluation protocol for incremental security measurements. For network operations, an event-aware estimate could help distinguish a configuration that is structurally dangerous from a behavioral alert that is suspicious but unconfirmed. For incident response, the proposed framework will explore whether SDN policies can translate those distinctions into proportionate and reversible interventions. The goal is not to assert that a computed risk score measures the real probability of a zero-day compromise; it is to assess the usefulness and limitations of an explicit decision-support proxy.

7 Literature Review and Related Work

7.1 Classical k-Zero Day Safety and Network Diversity

The original metric treats vulnerability uncertainty as a path-structure problem: an attacker must satisfy conditions along some feasible path, and the weakest path determines target safety [3, 4]. Related computational work addresses the cost of estimating this property in larger configurations [8, 15]. Network diversity analyses add the insight that repeated exposure to a common weakness can reduce effective independence among attack steps [5]; therefore, this proposal will count *distinct assumed vulnerabilities*, not merely hops or edges. Network attack-surface studies additionally motivate measuring exposed routes and services apart from the minimum chain length [6, 7].

7.2 Attack Graphs and Lateral Movement

An attack graph represents attacker preconditions, privilege states, and feasible transitions. The literature describes different graph semantics and algorithms, which makes

a precise choice of node and edge interpretation essential [9, 10]. Lateral movement provides an operational scenario for testing whether newly reachable intermediate hosts change paths to a high-value target [16]. A fast graph update is not sufficient if it silently omits dependencies created by a new rule; exact comparison against a reference model is therefore a core evaluation requirement.

7.3 SDN Security and Flow-Based Detection

OpenFlow provides programmability and switch telemetry but also exposes control-plane stress and policy-enforcement challenges [1, 14]. Security monitoring studies show the promise of flow-derived features, including packet and byte counts, duration, and traffic distributions [11, 12]. Broad anomaly-detection and cybersecurity-ML reviews warn that rare behavior, class imbalance, and distribution shifts complicate interpretation [17, 18]. Deep models may detect complex patterns but can create explainability and reproducibility challenges [19, 13]. Reviews specific to zero-day detection emphasize that a classifier's success on *held-out attack families* is not equivalent to proving the detection of truly undisclosed vulnerabilities [20].

7.4 Dynamic Risk Measurement and the Remaining Opportunity

The literature supports attack-path scoring and anomaly monitoring as separate mechanisms, but a prototype that couples SDN event semantics, incremental path correctness, an explicitly bounded score, and rollback-aware mitigation still needs to demonstrate practical utility under a common evaluation protocol. This proposal will use interpretable statistical detectors as baselines; optional clustering and time-series analysis may be tested if the collected data justify them [21, 22, 23]. These techniques are *candidates*, not selected or validated findings.

Table 1: *Positioning of the proposed research against relevant lines of work.*

Research line	Established focus	Question taken forward
k-zero day safety [4]	Minimum distinct unknown vulnerabilities along an attack path	State changes, path identity and incremental accuracy
Attack graphs [9]	Compromise preconditions and multi-step routes	Local updates with full-recompute checks
SDN security [14]	Programmable forwarding and control-plane protection	Bounded, auditable policy responses
Anomaly detection [11]	Behavioral deviations in network telemetry	Fusion with structural metrics and false-positive cost

8 Proposed Research Methodology

8.1 Research Design and Phases

The study will employ design-science prototyping and controlled quantitative experiments. The prototype will be built and assessed in six iterative phases: (1) formal model and assumptions, (2) telemetry and event acquisition, (3) attack-graph construction and differential updates, (4) anomaly and risk estimation, (5) guarded mitigation, and (6) repeated comparative evaluation. Each phase will produce a testable artifact or specification. The primary independent variables will include network size, topology-change rate, flow-table churn, anomaly intensity, the policy scenario, and risk-scoring configuration. Dependent variables will include assessment latency, path correctness, detection behavior, mitigative impact, and controller overhead.

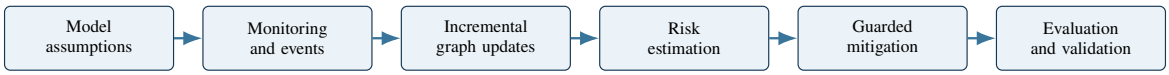


Figure 2: *Planned research phases, from formal assumptions to comparative evaluation.*
Author-created proposed research methodology.

8.2 Experimental Architecture

A Mininet emulation will host Open vSwitch instances, end hosts, an untrusted ingress segment, application-tier nodes, and one or more critical targets. An open-source controller, initially a Ryu-compatible OpenFlow test environment subject to version and maintenance checks, will maintain the control plane and expose topology and flow-table events. A Python-based research service will collect event records, maintain graph state, run an initial interpretable anomaly model, and compute k-safety and risk. A mitigation adapter will request rule additions, deletions, rate limiting, or segment isolation through controller-approved APIs. A separate experiment orchestrator will generate event sequences and collect ground-truth timestamps. Only laboratory networks under the researcher's control will be used.

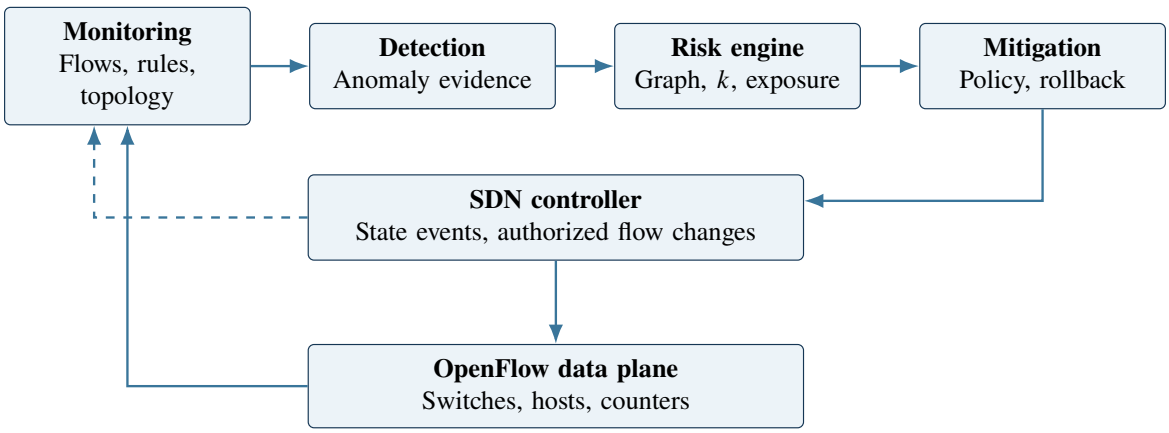


Figure 3: *Proposed SDN-aware k-zero day safety prototype and closed-loop control architecture.*
Author-created, proposed components; no implementation is claimed.

8.3 Monitoring and Feature Engineering

The collector will combine switch counters (packet and byte counts, durations, per-port aggregates) with controller-sourced flow-rule modifications, topology observations, and policy logs. It will distinguish a *controller command issued* timestamp from a *switch state observed* timestamp, because command delivery does not guarantee instantaneous installation. Raw cumulative counters will be converted into windowed rates using elapsed time; resets, counter wraparound, duplicate notifications, and missing observations will be detected and flagged. Host- and target-level features will include source/destination diversity, flow churn rate, short-lived connection bursts, and approximate target reachability indicators. Feature extraction will be constrained to metadata that is collectable without inspecting private payloads.

Table 2: *Proposed telemetry inputs and their interpretation.*

Input	Example source	Planned use and limitation
Flow packets / bytes	OpenFlow statistics	Windowed rates; subject to sampling and counter reset
Flow duration / port diversity	Switch and flow metadata	Behavioral context, not proof of malicious traffic
Flow adds / deletes	Controller event log	Changes in reachability; requires installed-state confirmation
Host/link changes	Controller discovery and link events	Local graph invalidation; delayed discovery may cause stale state
Asset importance	Research policy inventory	Criticality weight, preassigned and documented
Anomaly severity	Detection engine	Behavioral evidence with calibrated uncertainty

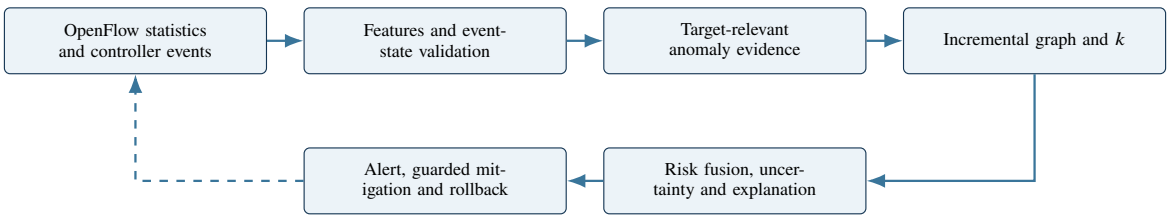


Figure 4: *Proposed real-time telemetry, feature processing, risk assessment, and feedback workflow.*
Author-created workflow inspired by the supplied source paper's Figure 6.

8.4 Anomaly Detection and Calibration

A transparent baseline detector will estimate deviations in normalized flow rates, port diversity, and flow churn relative to benign training windows. Robust z-score or quantile thresholds will provide a simple, explainable benchmark. If the data volume and

class separation justify them, a second method (for example, isolation-based outlier detection or clustering) may be trained and compared. Training will use one set of time windows/topologies; threshold selection will use a separated validation set; and final reporting will use held-out scenario seeds and, where feasible, entire unseen traffic families. Label leakage will be prevented by grouping temporally related flows within the same experimental split. Output $A_{\text{sev}}(T, t) \in [0, 1]$ will be a calibrated *anomaly severity*, not a confirmed zero-day probability.

8.5 Dynamic Attack-Graph Representation

The model will define vertices for attacker-controlled entry conditions, host/service access, privilege states, and protected targets. Edges will represent transitions possible under assumed attack prerequisites and observed connectivity. A topology or flow-rule event will first update a reachability dependency map; this will trigger invalidation and regeneration of impacted exploit-possibility edges. All graph events will be versioned by observation time and sequence number. Every event batch will produce (i) an incremental graph and (ii) an independent periodically recomputed reference graph. A mismatch will be logged with the smallest divergent set of nodes/edges, ensuring that speed cannot substitute for accuracy.

For zero-day assumptions, the prototype will use predeclared *hypothetical exploit opportunities* associated with reachable services or software-diversity classes. They are not asserted to correspond to undisclosed real vulnerabilities. Where multiple steps share the same assumed vulnerability identifier, that identifier will be counted only once. The study will vary these assumptions and show whether its comparative findings are stable under alternative mappings.

8.6 Incremental Update Strategy

The initial algorithm will maintain a mapping between network objects (switch ports, rule predicates, hosts, and services) and the attack-graph edges that depend on them. For each new event, it will identify affected dependency objects, invalidate relevant graph edges, apply replacement edges, and update only target-reachable portions of the graph. A target's k-value will be invalidated if any of its candidate minimizing paths could change; otherwise the previous value may be reused with an explicit consistency check. A full rebuild will be run on a configurable audit schedule, and always after a detected inconsistency. The implementation will record the number of updated nodes and edges, the time spent in each stage, and the fraction of events that require a full recomputation.

8.7 Risk Estimation and Decision Policy

The composite score will be calculated only after input timestamps, normalization, and data-confidence tags have been checked. The score will report each contributing term, the current minimum path assumptions, a data-freshness age, and a confidence status. A mit-

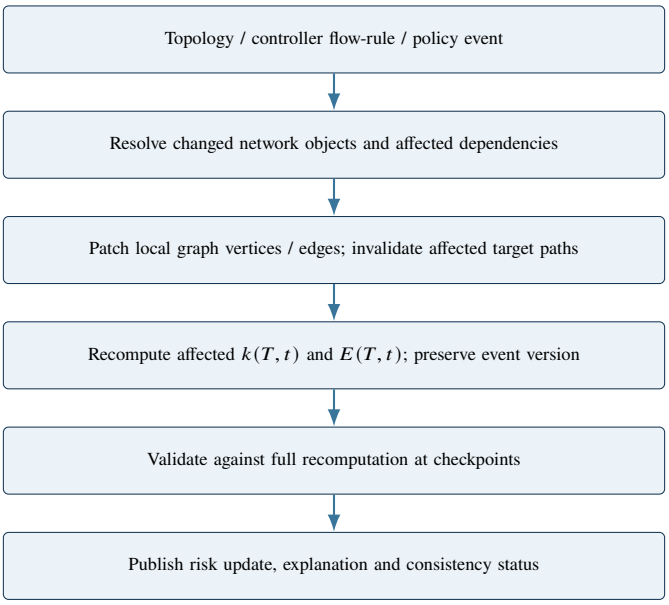


Figure 5: *Proposed incremental attack-graph update and consistency-check procedure.*
Author-created conceptual sequence, adapted in meaning from the supplied paper's Figure 5.

igation policy will map *empirically calibrated* decision regions to candidate actions. Initial thresholds, if needed during development, will be declared provisional and excluded from inferential claims. For critical targets, destructive actions such as segment isolation will require human authorization or a narrowly defined emergency rule. Automated actions will carry expiry timers, rule-priority checks, logging, and rollback instructions. Repeated flapping between actions will be reduced using hysteresis and minimum hold times.

9 Proposed Mathematical Model

9.1 Network State and Attack Paths

Let the time-indexed network state be

$$S(t) = \Big(V(t), L(t), F(t), Q(t), H(t)\Big), \tag{1}$$

where $V(t)$ represents observed devices and hosts, $L(t)$ active links, $F(t)$ effective forwarding rules, $Q(t)$ controller/security policies, and $H(t)$ observed host/service properties. Let T be a protected asset and $\mathcal{A}$ the defined attacker entry conditions. The attack graph $G(S(t), \mathcal{A})$ encodes feasible exploit preconditions under the modeling assumptions. $P(T,t)$ denotes its set of paths from $\mathcal{A}$ to compromise of T.

For each path p, let $Z(p)$ be the *set of distinct hypothetical unknown-vulnerability identifiers* on that path, and let $z(p) = |Z(p)|$. The source paper's structural k-zero day formulation is preserved:

$$\boxed{k(T,t) = \min_{p \in P(T,t)} z(p).} \tag{2}$$

A large finite k represents a structural requirement for more distinct unknown exploits; it is *not* a measured probability of compromise. Counting only edges would be incorrect when one hypothetical vulnerability enables more than one step. As a modeling convention, $P(T,t) = \varnothing$ will produce $k(T,t) = \infty$ (unreachable within the defined graph and assumptions), not a claim of absolute security. If a reachable path requires no assumed zero-day flaw, then $k(T,t) = 0$ and the target is already exposed by a modeled known-only path.

9.2 Exposure, Anomaly Severity, Criticality, and Exploitability

The exposure term $E(T,t) \in [0,1]$ will be a normalized function of attacker-to-target reachability, exposed services, and path multiplicity. Its definition will be fixed before final testing; one candidate is a weighted combination of normalized reachable-entry count, exposed-service fraction, and capped path-diversity indicators. Normalization constants will come from the training environment or predefined design limits, rather than from the test outcome itself. The detection term $A_{\text{sev}}(T,t) \in [0,1]$ will represent anomaly severity relevant to the target; $C(T) \in [0,1]$ will represent preassigned asset criticality; and $X(T,t) \in [0,1]$ will be a documented heuristic for exploit-opportunity evidence or uncertainty. In the absence of verifiable threat intelligence, X will not be described as a true exploitation probability.

9.3 Original Conceptual Composite Score

The source document supplies the following *illustrative*, unvalidated risk equation, here reproduced with asset-specific notation only where applicable:

$$R_{\text{src}}(T,t) = w_1 \frac{1}{k(T,t)} + w_2 A_{\text{sev}}(t) + w_3 C(T) + w_4 X(t) + w_5 E(T,t), \tag{3}$$

subject to $w_i \geq 0$ and $\sum_{i=1}^{5} w_i = 1$. In the proposed application, inputs other than $C(T)$ may vary with time. Equation (3) is *undefined at* $k = 0$; it also requires an explicit interpretation for $k = \infty$. Even with nonnegative normalized weights, the expression is not bounded on $[0,1]$ when $k = 0$. Therefore it cannot be deployed safely without a defined boundary convention or transformation.

9.4 Proposed Bounded Refinement and Uncertainty Handling

This study will evaluate the *proposed mathematical refinement*

$$\phi(k) = \begin{cases} \dfrac{1}{1+k}, & k \in \{0,1,2,\ldots\}, \\ 0, & k = \infty, \end{cases} \tag{4}$$

$$R_{\text{prop}}(T,t) = w_1 \phi(k(T,t)) + w_2 A_{\text{sev}}(T,t) + w_3 C(T) + w_4 X(T,t) + w_5 E(T,t), \tag{5}$$

where all terms and weights are in $[0, 1]$ and the weights sum to one, giving $0 \leq R_{\text{prop}} \leq 1$. This transformation is not a validated security law; it is a convenient bounded alternative enabling an explicit interpretation of $k = 0$ and graph unreachability. Potential changes to rank-order sensitivity at larger k must be tested. A missing network observation will not be silently treated as zero exposure: the system will instead attach a stale/uncertain status, optionally calculate best- and worst-case bounds, and suppress aggressive automation when confidence is low.

Table 3: *Mathematical variables, ranges and interpretation.*

Symbol	Domain	Interpretation
$S(t)$	Stateful tuple	Controller-observed topology, links, rules, policies and host properties
$P(T, t)$	Path set	Modeled paths from attacker assumptions to target T
$k(T, t)$	$\mathbb{N}_0 \cup \{\infty\}$	Fewest distinct assumed zero-day opportunities on any path
$E(T, t)$	$[0, 1]$	Normalized attack-surface exposure proxy
$A_{\text{sev}}(T, t)$	$[0, 1]$	Target-relevant anomaly severity, not confirmed zero-day exploitation
$C(T)$	$[0, 1]$	Preassigned asset criticality
$X(T, t)$	$[0, 1]$	Explicit, uncertain exploit-opportunity heuristic
$w_1, \ldots, w_5$	≥ 0, sum 1	Calibrated or policy-selected weights
$R_{\text{prop}}(T, t)$	$[0, 1]$	Proposed composite decision-support score

9.5 Path Computation and Computational Tradeoffs

Unlike ordinary shortest-path problems, minimizing the number of *distinct labels* along a path is not generally equivalent to minimizing the number of weighted edges, because a shared hypothetical flaw may occur multiple times. The prototype will use an exact method for small graphs (bounded search or set-state dynamic programming where tractable), then explore search pruning or approximation with recorded deviation for larger graphs. An approximation will not be reported as the exact classical k-value. The study will distinguish the computational cost of updating graph structure from the cost of recomputing minimum distinct-label paths and assess both independently. This distinction is essential for a defensible scalability claim.

10 Proposed System Architecture

The proposed system will be organized around five interfaces, with explicit ownership and versioning. The *state interface* receives controller-verified topology and rule events; the *telemetry interface* receives sampled switch counters; the *detection interface* publishes time-stamped severity and evidence; the *assessment interface* publishes graph version, $k(T, t)$, exposure, risk components, freshness and explanation; and the *enforcement inter-*

face submits a bounded, auditable proposed action to the controller. Distinct interfaces will prevent behavioral alarms from being silently translated into assumptions about unknown vulnerabilities.

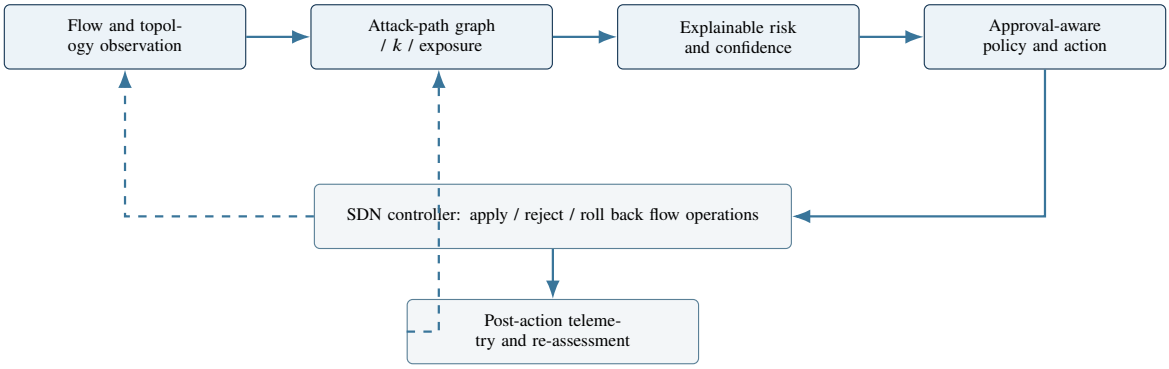


Figure 6: *Proposed mitigation decision, enforcement, rollback and feedback interfaces.*
Author-created conceptual diagram of the planned control loop.

The framework will operate in three modes: *monitor-only* (calculate and log without altering flow rules), *assisted* (prepare an action for operator approval), and *constrained automatic* (execute only allowlisted, reversible, low-impact responses). All comparative experiments will begin in monitor-only mode, then proceed to assisted/automatic policies within isolated testbeds once correctness and rollback checks pass. Each mitigation event will store the reason, score decomposition, applicable policy, requested change, observed installation result, time to recovery, and whether the modeled target exposure actually improved.

11 Experimental Design and Evaluation Plan

11.1 Testbed Configuration and Reproducibility

The testbed will use Mininet with Open vSwitch, a compatible open-source SDN controller, and independently logged traffic and event generators [24]. Experimental manifests will capture operating-system image, controller/Mininet/OpenFlow versions, network graph generator seed, resource allocations, switch counts, host counts, policy and access-rule templates, detection threshold configuration, and model version. Traffic generators may use iPerf for benign throughput loads, scripted connection bursts for anomalous patterns, and replayable packet or flow traces when permissible. The chosen controller must support reliable enumeration of effective rules and observable change timestamps; otherwise the architecture will be revised and the limitation documented.

A minimal topology will contain an untrusted host, two application intermediaries, multiple SDN switches, and a critical database target. Larger topologies will vary subnet segmentation and service diversity. Multiple independent scenario families will be generated with fixed random seeds and archived descriptions so that individual results can be recreated. Controlled attacks will be limited to the authorized emulated laboratory, and

the study will not deliberately deploy unknown exploits.

11.2 Experimental Scenarios

The proposal derives the following scenarios from the source paper's conceptual walk-through, while extending them into repeatable experiments:

S1. Stable baseline: Keep topology and rules fixed, establish benign-flow performance, and measure assessment consistency and idle monitoring overhead.

S2. Flow-rule shortcut: Add a rule that opens an alternative path to the protected target; verify whether a modeled shortcut reduces the target's distinct-label k and increases reachability exposure.

S3. Rule withdrawal and isolation: Remove the shortcut or isolate the implicated host; verify whether the relevant path disappears, whether graph and controller state agree, and what benign traffic is lost.

S4. Link failure and rerouting: Disable a link and force alternate forwarding; test cases in which the new path raises, lowers, or leaves k unchanged.

S5. Anomaly without path change: Generate a controlled traffic burst or unusual connection-diversity pattern; test whether anomaly severity can change while k remains constant.

S6. Host addition and lateral path: Introduce a reachable intermediary, modify service permissions, and examine the appearance or disappearance of multi-hop modeled paths.

S7. Flow-table churn and scale: Increase hosts, switches, rules, and event rates to compare incremental updates, full recomputation, controller CPU/memory, and tail latencies.

S8. False alert and rollback: Inject benign-but-unusual traffic to exercise suppression, approval, mitigation expiry, and restoration of legitimate connectivity.

11.3 Comparison Baselines and Ablations

Four configurations will run against matched scenario seeds and equivalent traffic loads: **B0** a fixed snapshot k-value refreshed only at a declared audit interval; **B1** event-triggered full-graph rebuild and exact recomputation; **B2** anomaly-only detection with matched action budgets; and **P** the proposed incremental graph, composite risk, and guarded mitigation system. Additional ablations will disable the anomaly component, the structural component, or automatic mitigation to estimate the contribution and cost of each. The full-rebuild model will serve as an *algorithmic reference* for the same modeling assumptions, not as empirical ground truth about actual unknown vulnerabilities.

Table 4: *Planned controlled comparisons and their principal purpose.*

ID	Configuration	Principal question
B0	Periodic static snapshot, no event updates	How stale does structural assessment become?
B1	Full rebuild after each event	Can incremental results match an exact reference faster?
B2	Anomaly-only alert/response	Does structural context improve decisions at fixed false-positive cost?
P	Incremental graph + risk + guarded mitigation	What is the end-to-end benefit and operational cost?
Ablations	Remove one risk term or mitigation stage	Which components materially affect observed outcomes?

11.4 Experimental Procedure and Statistical Analysis

Each scenario will begin with a clean, recorded switch/controller state. The orchestrator will synchronize available clocks, warm up traffic, establish a benign reference interval, inject a scripted event at a logged timestamp, and record every relevant stage until assessment and optional mitigation settle. Runs will be paired by topology and traffic seed. A pilot study will estimate event-latency variance and determine a defensible final sample size; the initial plan is at least 20 independent seeds per key scenario, adjusted by pilot-based uncertainty requirements rather than presented as an achieved sample. Medians, interquartile ranges, 95% confidence intervals (using appropriate bootstrap procedures), and paired differences will be reported. Confidence intervals will be favored over unsupported threshold-based significance claims. Multiple-comparison effects and temporal correlation between nearby flow observations will be addressed in the analysis.

11.5 Validation of the Mathematical Assumptions

The path model will be tested with deliberately constructed small graphs for which the exact minimum distinct-label count can be checked manually. The evaluation will vary assumed exploit-opportunity assignment, service diversity, attacker starting position, and missing telemetry to characterize sensitivity. Risk-score weights will be declared before final validation and may be selected via a training/validation split and a predeclared criterion such as decision utility subject to a false-positive budget. A single aggregate score cannot be assumed to be universally calibrated across organizations or topologies. Monotonicity, boundedness, and the effect of high asset criticality when a graph is unreachable will be inspected explicitly.

12 Performance Evaluation Metrics

12.1 Structural and Temporal Correctness

Graph agreement will compare the incremental graph with a canonical full rebuild, using edge/vertex differences and target reachability agreement. **k-agreement** will measure the fraction of event checkpoints with exact equality to the full-recompute reference. **Assessment update delay** will be the elapsed time between effective state-change observation and publication of a new graph-versioned result. **Staleness** will be the duration for which a published k-value refers to a superseded verified state. Raw event-time and processing-time distributions will be retained to identify backlogs and out-of-order events.

12.2 Detection and Mitigation Performance

For controlled, labeled anomaly episodes (*not genuine zero-day discoveries*), standard classification measures will be calculated:

$$\text{TPR} = \frac{TP}{TP + FN}, \qquad \text{FPR} = \frac{FP}{FP + TN}, \qquad \text{Precision} = \frac{TP}{TP + FP}. \tag{6}$$

Detection delay is the first qualifying alert minus the labeled anomaly onset; **action delay** is the time from eligible risk decision to confirmed switch action; and **end-to-end response time** is from event onset to confirmed mitigation. For each response, the study will record $\Delta k = k_{\text{post}} - k_{\text{pre}}$ when finite, change in $E(T, t)$, change in $R_{\text{prop}}(T, t)$, number of benign flows disrupted, rollback time, and restoration success. Unreachable-to-reachable transitions will be reported categorically rather than forcing infinity into an arithmetic mean.

12.3 Operational Overhead and Scaling

Monitoring cost will include controller CPU, memory, event-handling rate, statistics-request volume, and impact on flow setup time. Data-plane overhead will include throughput change and packet delay under identical offered loads. Attack-graph overhead will include graph size, local update time, exact k computation time, memory use, and the fraction of events triggering a full rebuild. The study will record p50, p95, and p99 end-to-end latency where the number of observations permits stable estimates. Resource consumption will be measured on the same allocated hardware and under identical traffic conditions.

13 Expected Results and Anticipated Contributions

The study is expected to produce a documented prototype, a formal interpretation of time-indexed k-safety, an incremental graph-update procedure with differential tests, an auditable risk calculation, and an experimental dataset of controller events and controlled traffic scenarios. It may demonstrate reduced update latency relative to full rebuilds in some regimes, but that expectation remains a hypothesis; at high churn, path diversity,

Table 5: *Metrics, measurements and interpretation safeguards.*

Metric	Measurement	Interpretive caution
Exact k agreement	Matching targets / evaluated checkpoints	Relative to the same assumed graph model only
Graph update latency	Observed event to versioned output	Must include queuing and timestamp uncertainty
Detection rate / FPR	Labeled anomalous / benign trials	Controlled anomalies are not validated zero-days
Mitigation response time	Event onset to installed change	Controller acknowledgment is not always switch confirmation
Latency and throughput	Difference from matched benign baseline	Separate policy disruption from measurement overhead
Controller CPU / memory	Traced utilization and peak values	Report testbed specifications and concurrent loads
Risk and exposure change	Before / after under versioned state	A lower score is not proof of eliminated compromise risk

or graph complexity, incremental maintenance may perform no better or may incur consistency costs. Similarly, composite scoring may improve the utility of response decisions only if its components are appropriately normalized and the false-positive budget is controlled.

The anticipated scientific deliverables are: *(i)* a precise operational model and edge-case treatment for dynamic structural safety, *(ii)* a reproducible correctness/latency benchmark for event-driven graph updates, *(iii)* an evaluation of whether structural and behavioral evidence complement each other in policy decisions, and *(iv)* documented failure modes, limitations, and guidance on safe deployment boundaries. Findings will be presented as measured tradeoffs rather than as proof that zero-day attacks can be identified with certainty.

14 Research Limitations and Threats to Validity

Construct validity. The count of hypothetical unknown-vulnerability identifiers is a model-dependent proxy; it does not establish how many undisclosed exploitable flaws actually exist. Different mappings of services to exploit opportunities may change rank order, and the test results must expose that sensitivity. The proposed score is a decision-support index, not a calibrated compromise probability unless separately validated against meaningful outcomes.

Internal validity. Controller event ordering, delayed topology discovery, counter resets, traffic generation artefacts, and shared compute resources can bias latency or detection measures. Clean resets, controller-versus-switch timestamp separation, matched baselines, and instrumentation logs will reduce but not eliminate these effects.

External validity. Mininet is a controlled emulator and cannot reproduce all controller deployments, switch ASIC behavior, traffic mixtures, enterprise policies, or multi-controller failures. Positive findings will not be generalized to production without independent validation. A single open-source controller and a single resource configuration could narrow applicability.

Statistical validity. Paired trials may exhibit serial correlation and topology-dependent variability. Pilot-guided replication, seed separation, confidence intervals, and disclosed unsuccessful runs will be necessary. A seemingly large count of individual flows cannot replace independent scenario replicates.

Operational risks. False alarms could lead to unnecessary network blocking. A policy might appear to raise k while causing service denial, or while exposing another target via rerouting. Thus, the evaluator must track multiple assets, service-level impacts, rollback, and stale assessment states as well as the selected target's score.

15 Research Ethics and Security Considerations

All experiments will take place in a dedicated, isolated, researcher-authorized network emulation environment. Simulated attacker starting conditions, traffic bursts, scanning-like behavior, and rule modifications will be confined to the laboratory; the study will not use live production targets, real unauthorized credentials, or exploitation of genuinely unknown vulnerabilities. Packet contents and personal identifiers will not be necessary for the core metrics, and telemetry retained for publication will be minimized and sanitized. Experiment scripts, logs, and controller credentials will be protected using role-limited access. Mitigation functionality will require dry-run testing, allowlists, expiry/rollback capability, and explicit human approval for actions that could disrupt critical services. The researcher will document the exact threat model, assumptions, and any residual safety risks before experiments.

16 Research Work Plan and Timeline

A provisional eight-month plan is proposed, subject to departmental approval, access to hardware, and the results of preliminary trials. The schedule is a planning estimate rather than a declared institutional deadline.

16.1 Milestones and Decision Gates

At the end of Month 2, the formal threat model, exactness-test cases, and implementation plan will be reviewed. At the end of Month 4, the telemetry pipeline and a reference full-rebuild attack model must produce reproducible outputs; otherwise the incremental subsystem will not be declared ready for evaluation. At the end of Month 6, safe mitigation and rollback tests must pass before automatic actions are activated. The final phase will prioritize a reproducible experiment archive and analysis, even if the eventual evidence

Table 6: *Proposed eight-month research schedule (• = active period).*

Workstream	M1	M2	M3	M4	M5	M6	M7	M8
Detailed literature review / protocol	•	•						
Threat model, mathematics, design	•	•	•					
Mininet and telemetry pipeline		•	•	•				
Graph maintenance / exactness tests			•	•	•			
Anomaly/risk model and calibration				•	•	•		
Mitigation safeguards / integration					•	•		
Experiments and statistical analysis						•	•	
Proposal-to-thesis reporting / revision							•	•

rejects one or more proposed hypotheses.

17 Conclusion

This proposal advances a specific, testable investigation of how classical k-zero day safety can be maintained and used in an SDN environment where reachability, policy, and traffic observations change continuously. It preserves the structural meaning of the original metric while introducing an explicitly provisional risk-scoring refinement, a versioned incremental attack-graph design, and a feedback-controlled mitigation architecture. The research will compare proposed and baseline methods using controlled Mininet experiments and will evaluate not only update speed and anomaly recognition but also exactness, operational cost, and unintended disruption. Its contribution will depend on the results of these future experiments. No implementation, validated performance improvement, or real zero-day exploitation detection is claimed at this stage.

References

[1] Nick McKeown, Tom Anderson, Hari Balakrishnan, Guru Parulkar, Larry Peterson, Jennifer Rexford, Scott Shenker, Jonathan Turner. "OpenFlow: Enabling Innovation in Campus Networks," *ACM SIGCOMM Computer Communication Review*, vol. 38, no. 2, pp. 69–74, 2008.

[2] Thomas D. Nadeau, Ken Gray. *SDN: Software Defined Networks: An Introduction*. O'Reilly Media, Sebastopol, CA, 2013.

[3] Lingyu Wang, Sushil Jajodia, Anoop Singhal, Steven Noel. "k-Zero Day Safety: Measuring the Security Risk of Networks against Unknown Attacks," in *Proceedings of the 15th European Symposium on Research in Computer Security (ESORICS)*, series Lecture Notes in Computer Science, vol. 6345, Springer, pp. 573–587, 2010.

[4] Lingyu Wang, Sushil Jajodia, Anoop Singhal, Pengsu Cheng, Steven Noel. "k-Zero Day Safety: A Network Security Metric for Measuring the Risk of Unknown Vulnerabilities," *IEEE Transactions on Dependable and Secure Computing*, vol. 11, no. 1, pp. 30–44, 2014.

[5] Ming Zhang, Lingyu Wang, Sushil Jajodia, Anoop Singhal, Massimiliano Albanese. "Network Diversity: A Security Metric for Evaluating the Resilience of Networks against Zero-Day Attacks," *IEEE Transactions on Information Forensics and Security*, vol. 11, no. 5, pp. 1071–1086, 2016.

[6] Ming Zhang, Lingyu Wang, Sushil Jajodia, Anoop Singhal. "Network Attack Surface: Lifting the Concept of Attack Surface to the Network Level for Evaluating Networks' Resilience Against Zero-Day Attacks," *IEEE Transactions on Dependable and Secure Computing*, vol. 18, no. 1, pp. 310–324, 2021.

[7] Pratyusa K. Manadhata, Jeannette M. Wing. "An Attack Surface Metric," *IEEE Transactions on Software Engineering*, vol. 37, no. 3, pp. 371–386, 2011.

[8] Massimiliano Albanese, Sushil Jajodia, Anoop Singhal, Lingyu Wang. "An Efficient Approach to Assessing the Risk of Zero-Day Vulnerabilities," in *Proceedings of the International Conference on Security and Cryptography (SECRYPT)*, 2013.

[9] Kengo Zenitani. "Attack Graph Analysis: An Explanatory Guide," *Computers & Security*, vol. 126, pp. 103081, 2023. doi: https://doi.org/10.1016/j.cose.2022.103081.

[10] Harjinder S. Lallie, Kurt Debattista, Jay Bal. "A Review of Attack Graph and Attack Tree Visual Syntax in Cyber Security," *Computer Science Review*, vol. 35, pp. 100219, 2020.

[11] S. K. Dey, M. M. Rahman. "Effects of Machine Learning Approach in Flow-Based Anomaly Detection on Software-Defined Networking," *Symmetry*, vol. 12, no. 1, pp. 7, 2020.

[12] N. Sultana, N. Chilamkurti, W. Peng, R. Alhadad. "Survey on SDN Based Network Intrusion Detection System Using Machine Learning Approaches," *Peer-to-Peer Networking and Applications*, vol. 12, pp. 493–501, 2019.

[13] S. Faezi, A. Shirmarz. "A Comprehensive Survey on Machine Learning Using in Software Defined Networks (SDN)," *Human-Centric Intelligent Systems*, vol. 3, pp. 312–343, 2023.

[14] Seungwon Shin, Vinod Yegneswaran, Phillip Porras, Guofei Gu. "AVANT-GUARD: Scalable and Vigilant Switch Flow Management in Software-Defined Networks," in *Proceedings of the ACM SIGSAC Conference on Computer and Communications Security (CCS)*, pp. 413–424, 2013. doi: https://doi.org/10.1145/2508859.2516684.

[15] Lingyu Wang, Sushil Jajodia, Anoop Singhal, Pengsu Cheng, Steven Noel. "k-Zero Day Safety: Evaluating the Resilience of Networks Against Unknown Attacks," in *Network Security Metrics*, Springer, Cham, pp. 73–94, 2017.

[16] Christos Smiliotopoulos, Georgios Kambourakis, Constantinos Kolias. "Detecting Lateral Movement: A Systematic Survey," *Heliyon*, vol. 10, no. 4, pp. e26317, 2024.

[17] Varun Chandola, Arindam Banerjee, Vipin Kumar. "Anomaly Detection: A Survey," *ACM Computing Surveys*, vol. 41, no. 3, pp. 1–58, 2009.

[18] Anna L. Buczak, Erhan Guven. "A Survey of Data Mining and Machine Learning Methods for Cyber Security Intrusion Detection," *IEEE Communications Surveys & Tutorials*, vol. 18, no. 2, pp. 1153–1176, 2016.

[19] Yann LeCun, Yoshua Bengio, Geoffrey Hinton. "Deep Learning," *Nature*, vol. 521, no. 7553, pp. 436–444, 2015.

[20] Yang Guo. "A Review of Machine Learning-Based Zero-Day Attack Detection: Challenges and Future Directions," *Computer Communications*, vol. 198, pp. 175–185, 2023. doi: https://doi.org/10.1016/j.comcom.2022.11.001.

[21] J. MacQueen. "Some Methods for Classification and Analysis of Multivariate Observations," in *Proceedings of the 5th Berkeley Symposium on Mathematical Statistics and Probability*, vol. 1, pp. 281–297, 1967.

[22] George E. P. Box, Gwilym M. Jenkins, Gregory C. Reinsel, Greta M. Ljung. *Time Series Analysis: Forecasting and Control*. ed. 5, John Wiley & Sons, Hoboken, NJ, 2015.

[23] Cristian Estan, George Varghese. "New Directions in Traffic Measurement and Accounting," *ACM SIGCOMM Computer Communication Review*, vol. 32, no. 4, pp. 323–336, 2002.

[24] Bob Lantz, Brandon Heller, Nick McKeown. "A Network in a Laptop: Rapid Prototyping for Software-Defined Networks," in *Proceedings of the 9th ACM SIGCOMM Workshop on Hot Topics in Networks (HotNets)*, 2010.